

VindobonaPay GmbH — Control Mapping Matrix

Deliverable 03 | ISO/IEC 27001:2022 (Clauses 4-10 + Annex A) <-> NIS2 (EU 2022/2555) <-> DORA (EU 2022/2554) <-> NIST CSF 2.0 | Version 2.0 | Fictional company for educational purposes

#	Security domain	ISO/IEC 27001 Clauses (4-10)	ISO/IEC 27001:2022 Annex A	NIS2 Directive	DORA Regulation	NIST CSF 2.0	Coverage	What the ISMS covers — and what the regulations add
D-01	Governance and management accountability	5.1, 5.2, 5.3, 9.3	A.5.1, A.5.2, A.5.4, A.5.36	Art. 20(1), 20(2); Art. 21(2)(f)	Art. 5(2), 5(3), 5(4); Art. 6(4), 6(5), 6(6)	GV.RR, GV.PO, GV.OV	Partial support	The ISMS provides policies, roles and management review (Clauses 5 and 9.3). Both regulations go further: the management body is personally accountable and must receive cybersecurity training, and DORA requires the ICT risk framework to be reviewed yearly and audited internally by auditors with ICT expertise.
D-02	Information security risk management	6.1.1, 6.1.2, 6.1.3, 8.2, 8.3	A.5.9, A.5.31	Art. 21(2)(a)	Art. 6, Art. 8	GV.RM, ID.RA	Partial support	The risk assessment methodology and risk register (Deliverable 01) satisfy the core requirement. DORA expects an ICT-specific risk management framework and a documented digital operational resilience strategy.
D-03	Asset management and information classification	4.3, 8.1	A.5.9, A.5.10, A.5.12, A.5.13	Art. 21(2)(i)	Art. 8	ID.AM	Strong support	Asset inventory and classification are addressed by the ISMS. DORA adds the mapping of assets supporting critical or important functions.
D-04	Identity, access control and authentication	8.1	A.5.15, A.5.16, A.5.17, A.5.18, A.8.2, A.8.3, A.8.5	Art. 21(2)(i), 21(2)(j)	Art. 9	PR.AA	Strong support	Annex A covers identity lifecycle, access rights and authentication. NIS2 names multi-factor authentication explicitly, which the ISMS already implements.
D-05	Human resources security and awareness	7.2, 7.3	A.6.1 to A.6.6, A.6.8	Art. 20(2); Art. 21(2)(g)	Art. 13(6); Art. 5(4)	PR.AT	Partial support	Screening, contracts, training and disciplinary process are covered, and Clauses 7.2 and 7.3 require competence and awareness. The specific obligation to train the management body comes from the regulations, not from Annex A.
D-06	Cryptography and data protection	8.1	A.8.24, A.8.10, A.8.11, A.8.12, A.5.34	Art. 21(2)(h)	Art. 9	PR.DS	Strong support	Encryption, key management and data protection are addressed. GDPR obligations run in parallel for personal data.
D-07	Physical and environmental security	8.1	A.7.1 to A.7.14	Art. 21(2)(i)	Art. 9	PR.IR, PR.PS	Strong support	Annex A is more detailed than either regulation in this area. For a cloud-first company the on-premises footprint is limited to the Vienna office.
D-08	Operations, configuration and vulnerability management	8.1	A.8.7, A.8.8, A.8.9, A.8.19, A.8.32	Art. 21(2)(e)	Art. 7, Art. 9	PR.PS	Strong support	Malware protection, patching, hardening and change management are covered by the ISMS.
D-09	Network and communications security	8.1	A.8.20, A.8.21, A.8.22, A.8.23	Art. 21(2)(i), 21(2)(j)	Art. 9	PR.IR	Strong support	Network segmentation, filtering and secure services are addressed. NIS2 also refers to secured emergency communications.
D-10	Logging, monitoring and detection	9.1	A.8.15, A.8.16, A.8.17	Art. 21(2)(b)	Art. 10	DE.CM, DE.AE	Partial support	The ISMS requires logging, monitoring and evaluation (Clause 9.1). DORA is more prescriptive on detection mechanisms, alert thresholds and the resources dedicated to monitoring anomalous activity.
D-11	Incident management and response	10.1, 10.2	A.5.24, A.5.25, A.5.26, A.5.27, A.5.28	Art. 21(2)(b); Art. 23(1)	Art. 17, Art. 18	RS.MA, RS.AN, RS.MI	Partial support	Incident handling and corrective action are covered (Clauses 10.1 and 10.2). DORA adds a defined classification of incidents against regulatory criteria, which determines what must be reported.
D-12	Business continuity, backup and recovery	8.1	A.5.29, A.5.30, A.8.13, A.8.14	Art. 21(2)(c)	Art. 11, Art. 12	RC.RP, RC.CO, PR.IR	Partial support	Backup and continuity are addressed. DORA requires ICT business continuity policies, recovery objectives and periodic testing of recovery plans as a regulatory obligation.
D-13	Supplier and ICT third-party risk	4.2, 8.1	A.5.19, A.5.20, A.5.21, A.5.22, A.5.23	Art. 21(2)(d); Art. 22	Art. 28, 29, 30 (Art. 31-44: oversight of critical ICT providers — supervisory context)	GV.SC	No direct support	Annex A requires supplier security management, but DORA sets dedicated obligations with no Annex A equivalent: a register of contractual arrangements, mandatory contractual provisions, concentration risk assessment and exit strategies for critical functions.
D-14	Secure development and application security	8.1	A.8.25, A.8.26, A.8.27, A.8.28, A.8.29, A.8.31, A.8.33	Art. 21(2)(e)	Art. 8, Art. 9	PR.PS	Strong support	Secure SDLC, code review and testing are covered by the ISMS. Relevant for VindobonaPay because all development is in-house.
D-15	Digital operational resilience testing	9.1, 9.2	A.8.29 (partial), A.5.30 (partial)	Art. 21(2)(f)	Art. 24, 25 (testing programme); Art. 26, 27 (TLPT)	ID.IM	No direct support	The ISMS tests controls through internal audit and penetration testing. DORA requires a formal, documented testing programme covering systems supporting critical functions, and threat-led penetration testing for entities identified by the competent authority.
D-16	Regulatory reporting and contact with authorities	4.2, 7.4	A.5.5, A.5.31, A.5.33	Art. 23(3) (early warning 24h), Art. 23(4) (notification 72h, final report 1 month)	Art. 19, 20, 21, 23	RS.CO, GV.OC	No direct support	Annex A requires contact with authorities and a legal register, but not the reporting workflow itself: deadlines, templates and recipients are set by the regulations and their technical standards.

Coverage ratings

Strong support	ISO/IEC 27001 requirements and controls substantially support the obligation, but regulatory validation is still required.
Partial support	ISO/IEC 27001 covers part of the requirement; additional processes or evidence are required.
No direct support	A dedicated regulatory process or deliverable is required.
Out of scope	Not relevant to the defined organizational scope.

What a mapping means: a mapping indicates that one requirement or control MAY SUPPORT another framework outcome. It does not establish equivalence, implementation effectiveness or legal compliance. 'A.5.19 -> DORA Article 28' means the control contributes to the obligation, not that implementing the control satisfies the article.

Annex A is not the whole standard: governance, competence, monitoring, internal audit and management review map to the management-system clauses (4-10), which is why they are shown in a separate column.

DORA applies to VindobonaPay as a financial entity. For the purposes of Article 4 of NIS2, DORA is sector-specific Union legislation: where it provides equivalent ICT risk-management and incident-reporting requirements, the corresponding NIS2 obligations do not apply to the same entity. NIS2 references are retained as a comparative baseline (see Deliverable 04).

DORA Articles 31-44 govern the designation and oversight of critical ICT third-party service providers and are addressed to the ESAs, the Lead Overseer and the providers themselves. They are shown as supervisory context, not as direct obligations of VindobonaPay.

Sources: EUR-Lex (Directive (EU) 2022/2555; Regulation (EU) 2022/2554), NIST CSF 2.0. No standard or regulatory text is reproduced: references and descriptions are written in my own words.

Obligations not satisfied by Annex A alone

Regulatory requirements that an ISO/IEC 27001 ISMS supports but does not automatically fulfil.

#	Obligation	Source	Why an ISO/IEC 27001 ISMS is not enough on its own	Addressed in
G-01	Register of information on contractual arrangements with ICT providers	DORA Art. 28(3)	Annex A requires supplier records, not a structured register in a regulatory format submitted to the authority.	Deliverable 05
G-02	Mandatory contractual provisions in ICT contracts	DORA Art. 30	A.5.20 requires security clauses in agreements, but not the specific provisions DORA lists (access, audit, termination, subcontracting).	Deliverable 05
G-03	Assessment of ICT concentration risk	DORA Art. 29	Not addressed by Annex A: it is a portfolio-level analysis of dependency on a small number of providers.	Deliverable 05
G-04	Exit strategies for ICT services supporting critical functions	DORA Art. 28(8)	A.5.23 mentions cloud exit planning; DORA makes it an obligation with defined content for critical functions.	Deliverable 05
G-05	Digital operational resilience testing programme	DORA Art. 24, 25	Annex A requires security testing in development; DORA requires a documented programme covering systems supporting critical functions, at least yearly.	Deliverable 05
G-06	Threat-led penetration testing (TLPT)	DORA Art. 26, 27	No equivalent in Annex A. Conditional obligation: applies to entities identified by the competent authority, with specific requirements for testers.	Deliverable 05
G-07	Classification of ICT incidents against regulatory criteria	DORA Art. 18	A.5.25 requires triage criteria set by the organization; DORA sets the criteria that determine whether an incident is major.	Deliverable 05
G-08	Reporting of major ICT-related incidents (initial, intermediate, final report)	DORA Art. 19	Annex A does not define reporting deadlines or templates. Deadlines are set by the regulation and its technical standards.	Deliverable 05
G-09	Incident notification timeline (early warning 24h, notification 72h, final report 1 month)	NIS2 Art. 23(3), 23(4)	Same point for the NIS2 regime. For financial entities the DORA reporting regime applies instead under the Article 4 carve-out (see G-08); retained here as a comparative reference.	Deliverable 04
G-10	Management body accountability and cybersecurity training	DORA Art. 5(2), 5(4), 13(6) (NIS2 Art. 20 comparative)	A.5.4 requires management support; the directly applicable basis is DORA, which makes the management body accountable for the ICT risk framework and requires regular training.	Deliverable 04 / 05
G-11	Yearly review and internal audit of the ICT risk management framework	DORA Art. 6(5), 6(6)	The ISMS requires internal audit (Clause 9.2), but DORA requires it specifically for the ICT risk framework, by auditors with ICT expertise.	Deliverable 05
G-12	Crisis communication plans	DORA Art. 14	Annex A covers incident communication indirectly; DORA requires plans for responsible disclosure to clients, counterparts and the public.	Deliverable 05

Mapping Summary — VindobonaPay GmbH

Version 2.0 — all values calculated automatically (COUNTIF) from the Mapping and Gap View sheets.

Security domains mapped	16
-------------------------	----

BY COVERAGE	
Strong support	7
Partial support	6
No direct support	3
Out of scope	0

Obligations beyond Annex A	12
----------------------------	----

The three domains rated 'No direct support' — ICT third-party risk, resilience testing and regulatory reporting — are the DORA-specific areas assessed in Deliverable 05.